Contact Person

Full name
Ahmed Emad Nasr

Job title / role
Incident Response Analyst

Department / team
Security Operations Center (SOC)

Email address
Ahmed.em.nasr@gmail.com

Phone number
+201018166445

The Incident

Date and time discovered:
March 13, 2025, 23:26:08.

How was the incident detected? (E.g., user report, monitoring system alert)

Suspected malicious endpoint activity triggered during investigation of SOC338, revealing phishing delivery and subsequent obfuscated PowerShell execution.

Detailed description of the incident (include what occurred, where, and how):

On March 13, 2025, at 09:44 AM, a phishing email was received by the internal user dylan@letsdefend.io from the external address update@windows-update.site (Source IP: 132.232.40.201).
The email subject was "Upgrade your system to Windows 11 Pro for FREE" and the action was "Allowed" by the Exchange server.
Endpoint logs for the host Dylan (172.16.17.216) show that at 23:26:08, the user accessed the URL https://windows-update.site/ via the browser, which established a network connection to the malicious IP 132.232.40.201.
Shortly after, at 23:26:19, heavily obfuscated PowerShell commands were executed on Dylan's machine.
The attacker used string replacement (e.g., ('ms]]]ht]]]a]]].]]]exe' -replace ']')) and fake reCAPTCHA comments (# ☑ 'I am not a robot - reCAPTCHA Verification ID: 3824') to evade detection and execute mshta.exe.
The mshta.exe process was used to call out to an external URL (https://overcoatpassably.shop/Z8UZbPyVpGfdRS/maloy.mp4) to likely download and execute the next stage payload.
Threat Intelligence flags the source IP 132.232.40.201 as being associated with "Lumma,Lumma Stealer".

Was the incident ongoing at the time of report?

☐ Yes ☒ No

Have any files, accounts, or systems been compromised?

☒ Yes ☐ No

If yes, please describe:

The endpoint Dylan (172.16.17.216) is fully compromised following the successful execution of obfuscated PowerShell and MSHTA commands linked to Lumma Stealer malware.

Notification

Was your supervisor or manager notified?

☒ Yes ☐ No

Date/time of notification:
April 5, 2026

Was the IT/security team alerted?

☒ Yes ☐ No

If yes, who was contacted and how? (e.g., email, phone, ticket)
Escalated to the Incident Response team.

Containment Measures

What immediate actions were taken to contain the threat? (E.g., system shutdown, network isolation)

Host containment must be activated immediately for the Dylan workstation (172.16.17.216) via Endpoint Security to prevent data exfiltration by the infostealer.

Were any user accounts disabled, firewalls updated, or services suspended?

☒ Yes ☐ No

If yes, provide details:

- Blocked the malicious IP (132.232.40.201), the phishing domain (windows-update.site), and the payload delivery domain (overcoatpassably.shop) on perimeter firewalls and web proxies.
- Initiated a mandatory password reset and session revocation for user Dylan across all active directory and cloud services, due to the nature of Lumma Stealer.

Impacted Services Measures

List any systems, devices, or applications affected by the incident:

Dylan (IP: 172.16.17.216).

Estimated number of affected users, if applicable:

1 user (Dylan).

Was there any known data loss or exposure?

☒ Yes ☐ No

If yes, describe the type of data (e.g., personal info, credentials, financial):

High probability of credential, session token, and sensitive file exfiltration. Lumma Stealer is specifically designed to harvest this data from infected endpoints.

Preliminary Analysis *(Optional)*

Suspected cause or entry point (e.g., phishing email, unpatched software):

Suspected cause or entry point (e.g., phishing email, unpatched software):

- A deceptive phishing email bypassing the Exchange filter, tricking the user into visiting a fake Windows update site, which subsequently launched a fileless/obfuscated malware execution chain.

Was the threat internal, external, or unknown?

☐ Internal ☒ External ☐ Unknown

Submitted by:

Ahmed Emad Nasr	Ahmed Emad Nasr	
Name	**Signature**	**Date submitted**